

مستند امنیت سامانه SaaS Chat AI

بخش ۱۱ راهنمای مستندات پروژه

نسخه سند: ۰.۱

تاریخ تدوین: ۱۵ جولای ۲۰۲۶

تهیه کننده: مبین یوسفی

مسیر خروجی: doc/LaTeX/11-Security/11-Security.tex

منابع بررسی شده: ArchitectureForMobin.md، Rahnama.md،

ReportForSale.md و کدهای backend

مستند کنترل های امنیتی، مدل تهدید، احراز هویت، مجوزدهی، مدیریت رازها، ثبت
رخداد و آمادگی عملیاتی

فهرست مطالب

۱	هدف و دامنه سند	۲
۲	خلاصه وضعیت امنیتی	۲
۳	دارایی‌ها و مرزهای اعتماد	۳
۳	۱.۳ دارایی‌های حساس	۳
۳	۲.۳ مرزهای اعتماد	۳
۴	Authentication	۳
۳	۱.۴ ورود کاربران پزل	۳
۴	۲.۴ تغییر رمز	۴
۴	۳.۴ خروج از همه نشست‌ها	۴
۴	JWT	۴
۴	۱.۵ ساختار و امضا	۴
۴	۲.۵ اعتبارسنجی توکن	۴
۴	۳.۵ ریسک‌های JWT	۴
۵	Authorization	۵
۵	۱.۶ نقش‌ها	۵
۵	۲.۶ کنترل tenant و سایت	۵
۵	۳.۶ کنترل پلن و قابلیت	۵
۵	CORS و امنیت ویجت	۵
۵	۱.۷ CORS پزل	۵
۶	۲.۷ CORS ویجت	۶
۶	۳.۷ ریسک‌های ویجت عمومی	۶
۶	Limit Rate و مقابله با سوءاستفاده	۶
۷	Encryption Hash، و مدیریت رمزها	۷
۷	۱.۹ Hash رمز عبور	۷
۷	۲.۹ Encryption	۷
۷	۳.۹ Management Secret	۷

۸	۱۰ امنیت آپلود فایل
۸	۱۱ Logging و Log Audit
۸	۱.۱۱ Audit مدیریت
۸	۲.۱۱ Handling Error
۹	۱۲ Headers Security
۹	۱۳ امنیت دیتابیس و ها Query
۹	۱۴ Model Threat
۱۰	۱۵ نگاشت Top OWASP ۱۰
۱۱	۱۶ Recovery و Backup
۱۱	۱۷ ریسک ها و شکاف های شناخته شده
۱۲	۱۸ چک لیست Production
۱۳	۱۹ جمع بندی

۱ هدف و دامنه سند

این سند وضعیت امنیتی سامانه AI Chat SaaS را بر اساس کدهای فعلی و مستندات معماری پروژه شرح می‌دهد. هدف، ثبت کنترل‌های موجود، نقاط اتکا، ریسک‌های باقی‌مانده و الزامات لازم برای آماده‌سازی production است. دامنه سند شامل API‌های PHP، پنل، ویجت عمومی، کنترل‌های tenant/site، مدیریت فایل، تنظیمات محیطی، ثبت رخداد و تهدیدهای رایج وب است.

سامانه از backend فایل‌محور PHP با PDO/MySQL استفاده می‌کند. هر endpoint به‌صورت مستقل های‌middleware لازم مانند CORS، احراز هویت، کنترل نقش، limit rate و پاسخ JSON امن را include می‌کند. بنابراین امنیت پروژه ترکیبی از کنترل‌های مشترک در backend/includes و کنترل‌های اختصاصی endpointهاست.

۲ خلاصه وضعیت امنیتی

بلوغ	وضعیت فعلی	حوزه
MVP مناسب برای	ورود با ایمیل/رمز، ذخیره رمز با password_hash، بررسی با password_verify، صدور JWT و rehash خودکار در login.	احراز هویت
خوب	RBAC با نقش‌های super_admin، customer_admin و agent؛ کنترل دسترسی سایت برای جلوگیری از IDOR.	مجوزدهی
خوب	امضای HS256، بررسی iat، exp، aud، iss، nbf، jti و token_version.	JWT
خوب، نیازمند تنظیم production	قوانین جدا برای پنل و ویجت؛ پنل با PANEL_ALLOWED_ORIGINS و ویجت با دامنه allowlist/سایت.	CORS
خوب	ذخیره محدودیت نرخ در جدول api_rate_limits برای login، تغییر رمز، ویجت و عملیات حساس.	Limit Rate
خوب	allowlist نوع فایل، بررسی MIME، اندازه، پسوندهای خطرناک، payload، PDF scan، check active-content و نام تصادفی.	Upload
متوسط تا خوب	ثبت رخدادهای مدیریتی سوپرادمین با redaction برای رمز، توکن و secret.	Log Audit
مناسب، وابسته به deployment	خواندن از .env؛ خطا در production برای JWT_SECRET ضعیف.	Secret Management
نیازمند تکمیل عملیاتی	رمز عبور hash می‌شود؛ انتقال امن به TLS در زیرساخت production وابسته است؛ رمزگذاری سطح دیتابیس در کد دیده نشد.	Encryption
نیازمند تکمیل	در کد مکانیزم backup دیده نمی‌شود؛ باید در DevOps/DB عملیاتی تعریف شود.	Backup/Recovery

۳ دارایی‌ها و مرزهای اعتماد

۱.۳ دارایی‌های حساس

- حساب‌های کاربران پِنل شامل ایمیل، نام، نقش، tenant و وضعیت فعال بودن.
- password_hash کاربران.
- های JWT فعال و مقدار token_version.
- داده‌های tenant، سایت‌ها، گفتگوها، پیام‌ها، ها visitor و پیوست‌ها.
- منابع دانش، AI، سوالات بی‌پاسخ، منابع crawl و تنظیمات پاسخ خودکار.
- رازهای محیطی مانند OPENAI_API_KEY، DB_PASS، JWT_SECRET و های URL تولیدی.
- لاگ‌های audit شامل actor، action، IP entity و user-agent.

۲.۳ مرزهای اعتماد

- مرورگر پِنل فقط از مسیرهای مجاز CORS می‌تواند به های API پِنل متصل شود، اما کنترل اصلی همچنان JWT و RBAC است.
- ویجت روی دامنه مشتری اجرا می‌شود و JWT ندارد؛ مرز اعتماد آن با Origin، site_key، وضعیت سایت/tenant و limit rate کنترل می‌شود.
- دیتابیس منبع حقیقت برای کاربر، نقش، tenant، site، limits plan access و revocation token است.
- storage فایل‌های upload شده عمومی‌تر از دیتابیس است؛ بنابراین validate-before-store و جلوگیری از اجرای فایل اهمیت بالایی دارد.
- crawler با اینترنت خارجی تعامل دارد و از نظر SSL SSRF و حجم پردازش باید محدود و مانیتور شود.

۴ Authentication

۱.۴ ورود کاربران پِنل

endpoint ورود backend/api/auth/login.php فقط متد POST را می‌پذیرد. ورودی ایمیل و رمز از JSON خوانده می‌شود، ایمیل normalize و validate می‌شود، سپس کاربر با PDO و query پارامتری از جدول کاربران بازیابی می‌شود. رمز با password_verify بررسی می‌شود و در صورت نیاز با password_needs_rehash و password_hash دوباره hash می‌شود.

کنترل‌های مهم در login:

- محدودیت نرخ بر اساس IP با سقف ۳۰ تلاش در ۱۵ دقیقه.
- محدودیت نرخ بر اساس ترکیب ایمیل و IP با سقف ۸ تلاش در ۱۵ دقیقه.
- پیام خطای یکسان برای ایمیل/رمز نامعتبر جهت کاهش enumeration. account.
- رد کاربر غیرفعال.
- رد کاربر غیرسوپرادمین در صورت نبود tenant یا غیرفعال بودن tenant.
- ثبت last_login_at پس از ورود موفق.
- پاک‌کردن رکوردهای limit rate پس از login موفق.

۲.۴ تغییر رمز

auth/change-password.php endpoint نیازمند JWT معتبر است. رمز جدید باید حداقل ۸ و حداکثر ۱۲۸ کاراکتر باشد و حداقل یک حرف و یک عدد داشته باشد. رمز جدید نباید با رمز فعلی یکسان باشد. پس از تغییر رمز، مقدار token_version یک واحد افزایش می‌یابد تا همه توکن‌های قبلی نامعتبر شوند.

۳.۴ خروج از همه نشست‌ها

auth/logout-all.php endpoint نیز با افزایش token_version همه نشست‌های قبلی را باطل می‌کند. این طراحی از نگهداری state کامل session در سرور سبک‌تر است و برای JWT مناسب است، چون هر درخواست protected دوباره مقدار token_version دیتابیس را با payload مقایسه می‌کند.

۵ JWT

۱.۵ ساختار و امضا

JWT در backend/includes/jwt.php بدون کتابخانه خارجی ساخته و بررسی می‌شود. الگوریتم فقط HS256 است و header باید typ=JWT و alg=HS256 داشته باشد. امضا با 'sha256' hash_hmac (...) تولید می‌شود و اعتبارسنجی با hash_equals انجام می‌گیرد.

```
Required claims:
iss, aud, sub, exp, iat, nbf, jti, token_version

Default TTL:
JWT_EXPIRATION_SECONDS=604800
JWT_MAX_TTL_SECONDS=604800
```

۲.۵ اعتبارسنجی توکن

در require_auth پس از decode، موارد زیر بررسی می‌شود:

- وجود sub، exp، iat، jti و token_version.
- معتبر بودن user id و وجود کاربر در دیتابیس.
- فعال بودن کاربر.
- تطبیق token_version payload با دیتابیس.
- تطبیق ایمیل و نقش payload با دیتابیس برای جلوگیری از استفاده از توکن قدیمی پس از تغییرات حساس.
- فعال بودن tenant برای کاربران غیرسوپرادمین.
- رعایت issuer، audience، max TTL و skew clock محدود.

۳.۵ ریسک‌های JWT

JWT در سمت کلاینت باید به‌گونه‌ای نگهداری شود که در برابر XSS کمترین آسیب را داشته باشد. در کد backend، token blacklist سراسری وجود ندارد و مکانیزم اصلی ابطال، token_version است. این

روش برای logout، all تغییر رمز و غیرفعال سازی کاربر کافی است، اما برای ابطال یک توکن منفرد پیش از انقضا نیاز به blacklist یا جدول session دارد.

۶ Authorization

۱.۶ نقش‌ها

سامانه از کنترل نقش در require_role استفاده می‌کند. نقش‌های اصلی عبارت‌اند از:

- `super_admin`: دسترسی مدیریتی کل سامانه، `tenant`ها، پلن‌ها، سایت‌ها، کاربران، اعلان‌ها و `audit`.
- `customer_admin`: مدیریت `tenant` خود، سایت‌ها، تیم، ویجت، دانش، AI و گزارش‌ها.
- `agent`: عملیات پشتیبانی، مشاهده گفتگوهای مجاز، پاسخ‌گویی، `presence` و پیشنهادهای AI در محدوده سایت‌های مجاز.

۲.۶ کنترل tenant و سایت

برای جلوگیری از IDOR، فایل `site-access.php` دسترسی `site` را جداگانه بررسی می‌کند:

- `super_admin` به همه سایت‌ها دسترسی دارد.
- `customer_admin` فقط به سایت‌های `tenant` خودش دسترسی دارد.
- `agent` فقط به سایت‌هایی دسترسی دارد که در جدول `agent_site_access` برای او ثبت شده‌اند.

این کنترل در های `endpoint` حساس `agent` و `customer` استفاده شده است. اگر `endpoint` مستقیم `site_id` یا `conversation_id` دریافت می‌کند، باید یا خودش `tenant/site` را `join` کند یا پس از بازیابی موجودیت، `require_site_access` را فراخوانی کند.

۳.۶ کنترل پلن و قابلیت

فایل `plan-limits.php` محدودیت‌های `tenant` و `plan` را اعمال می‌کند. کنترل‌های مهم:

- فعال بودن `tenant` و `plan`.
- محدودیت تعداد سایت.
- محدودیت تعداد `agent`.
- محدودیت تعداد گفتگوهای ماهانه.
- بودن قابلیت‌هایی مانند `ai_suggestions_enabled`، `ai_auto_reply_enabled` و `knowledge_base_enabled`.

۷ CORS و امنیت ویجت

۱.۷ CORS پلن

فایل `cors.php` مبدهای مجاز پلن را از `PANEL_ALLOWED_ORIGINS` یا `FRONTEND_URL` می‌خواند. در `origin production` نامعتبر برای `preflight` رد می‌شود. هدرهای مجاز شامل `Authorization` و `Content-Type` است.

هستند و متدهای رایج API مجاز شده‌اند.

۲.۷ CORS ویجت

فایل widget-cors.php برای APIهای عمومی ویجت طراحی شده است. چون ویجت روی دامنه مشتری نصب می‌شود و از cookie استفاده نمی‌کند، Access-Control-Allow-Credentials برای ویجت فعال نمی‌شود. کنترل‌های اصلی:

- رد origin خالی در production مگر با WIDGET_ALLOW_EMPTY_ORIGIN=true.
- validate کردن host و scheme.
- جلوگیری از injection header با رد \textbackslash n و \textbackslash r.
- تطبیق host مبدا با دامنه سایت و حالت‌های www.
- allowlist اضافه از WIDGET_ALLOWED_ORIGINS.
- مجاز بودن localhost فقط در محیط غیر production.

۳.۷ ریسک‌های ویجت عمومی

site_key به‌تنهایی secret کامل محسوب نمی‌شود، زیرا در اسکریپت embed سمت کاربر دیده می‌شود. بنابراین امنیت ویجت باید با ترکیب origin، validation، فعال بودن سایت، rate، limit، محدودیت پلن و کنترل وضعیت conversation تامین شود. در production مقدار WIDGET_ALLOW_EMPTY_ORIGIN باید false باشد.

۸ Limit Rate و مقابله با سوءاستفاده

فایل rate-limit.php شناسه درخواست‌کننده را از IP، user-agent و مقدار اضافی endpoint می‌سازد، سپس کلید hash شده را در جدول api_rate_limits ذخیره می‌کند. در صورت عبور از سقف، پاسخ 429 همراه با هدر Retry-After و فیلد retry_after_seconds برگردانده می‌شود.

سناریو	مکانیزم	اثر امنیتی
force brute Login	محدودیت IP و ایمیل+IP در auth/login.php	کاهش حمله حدس رمز
تغییر رمز	محدودیت کاربر+IP در change-password.php	کاهش force brute روی رمز فعلی
ویجت عمومی	محدودیت روی visitor، config، conversation، پیام، attachment، reply AI و messages	کاهش spam و مصرف بی‌رویه منابع
آپلود فایل	ترکیب endpoint limit rate و اعتبارسنجی فایل	کاهش DoS و abuse upload

برای production بهتر است limit rate فعلی با محدودیت در لایه proxy reverse یا WAF نیز تکمیل شود، چون محدودیت دیتابیزی در حملات حجیم قبل از رسیدن به PHP فشار روی دیتابیس ایجاد می‌کند.

۹، Encryption Hash و مدیریت رمزها

۱.۹ Hash رمز عبور

رمزهای عبور با `password_hash(..., PASSWORD_DEFAULT)` ذخیره می‌شوند. این انتخاب از الگوریتم پیش‌فرض امن PHP استفاده می‌کند و با ارتقای نسخه PHP امکان `rehash` تدریجی وجود دارد. `login` نیز در صورت نیاز `hash` قدیمی را `rehash` می‌کند.

۲.۹ Encryption

در کد فعلی، رمزگذاری اختصاصی برای داده‌های دیتابیس مشاهده نشد. داده‌های حساس در `transit` باید با `HTTPS/TLS` در سطح وب‌سرور و `balancer load` محافظت شوند. برای داده‌های `rest`، `at` باید سیاست رمزگذاری دیسک، `encrypted backup` و محدودیت دسترسی دیتابیس در سطح زیرساخت اعمال شود.

۳.۹ Management Secret

فایل `config/app.php` مقادیر حساس را از `.env` می‌خواند. `JWT_SECRET` در `production` اگر خالی، مقدار پیش‌فرض یا کمتر از ۳۲ کاراکتر باشد خطای امنیتی ایجاد می‌کند. نمونه `.env.example` شامل متغیرهای زیر است:

```
JWT_SECRET
DB_HOST
DB_NAME
DB_USER
DB_PASS
OPENAI_API_KEY
PANEL_ALLOWED_ORIGINS
WIDGET_ALLOWED_ORIGINS
UPLOAD_STORAGE_ROOT
UPLOAD_PUBLIC_URL
```

قواعد: `production`:

- فایل `.env` نباید در `git` `commit` شود.
- `JWT_SECRET` باید تصادفی، طولانی و متفاوت برای هر محیط باشد.
- دسترسی فایل `.env` باید فقط برای کاربر `runtime` لازم باشد.
- `rotation` برای `JWT_SECRET` باید با برنامه انجام شود، چون تغییر آن همه های `JWT` قبلی را نامعتبر می‌کند.
- `APP_DEBUG=false` و `APP_ENV=production` باید در `production` قطعی باشد.

۱۰ امنیت آپلود فایل

فایل `upload.php` یکی از کامل‌ترین کنترل‌های امنیتی پروژه است. نوع‌های مجاز شامل `jpeg`، `jpg`، `png`، `gif`، `webp` و `pdf` است. مسیر ذخیره با `channel` و تاریخ ساخته می‌شود و نام ذخیره‌شده با `random_bytes(24)` تولید می‌گردد.

کنترل‌های `upload`:

- بررسی `*.UPLOAD_ERR`.
- الزام `is_uploaded_file`.
- محدودیت اندازه با `UPLOAD_MAX_BYTES`.
- پاک‌سازی نام اصلی فایل و حذف کاراکترهای کنترلی.
- رد پسوندهای خطرناک حتی در نام‌های چندپسوندی مانند `file.php.jpg`.
- `allowlist` پسوند و MIME با `fileinfo`.
- رد‌های `payload` شامل `<?php`، `<script`، `<svg`، `HTML` و `shebang`.
- رد فایل `executable` ویندوز با امضای `MZ`.
- بررسی `dimensions` و MIME داخلی برای تصویر.
- بررسی امضای `PDF-%\` و `active content` در `PDF`.
- ساخت `htaccess` برای غیرفعال‌کردن اجرای فایل و بستن `index`، `listing`.
- بررسی اینکه مسیر `target` داخل `upload root` باقی بماند.

ریسک باقی‌مانده: اگر پروژه روی وب‌سروری غیر از Apache اجرا شود، `htaccess` اعمال نمی‌شود. در این حالت باید معادل Nginx/IIS برای جلوگیری از اجرای فایل‌ها و غیرفعال‌کردن `listing directory` تنظیم شود.

۱۱ Logging و Log Audit

۱.۱۱ مدیریت Audit

فایل `admin-audit.php` رخدادهای مدیریتی سوپرادمین را در `admin_audit_logs` ثبت می‌کند. داده‌های ثبت‌شده شامل `actor`، نقش، `action`، `entity`، `tenant`، `target site`، `user`، `plan`، توضیح، `IP`، `user-agent` و `old/new values` است.

برای جلوگیری از افشای اطلاعات حساس، تابع `admin_audit_sanitiz` کلیدهایی مانند `password`، `password_hash`، `new_password`، `token`، `secret`، `jwt_secret`، `api_key`، `authorization` و `cookie` را با [REDACTED] جایگزین می‌کند.

۲.۱۱ Handling Error

فایل `error-handler.php` در `production` نمایش خطا را خاموش می‌کند و خطاهای جدی را با پیام عمومی `Internal server error` برمی‌گرداند. تابع `json_response` نیز در `production` کلیدهای حساس خطاهای `5xx` مانند `debug`، `trace`، `file`، `line`، `sql` و `pdo_error` را حذف می‌کند.

۱۲ Headers Security

فایل security-headers.php هدرهای امنیتی عمومی را برای APIها ارسال می‌کند:

```
X-Content-Type-Options: nosniff •
X-Frame-Options: DENY •
Referrer-Policy: no-referrer •
X-Permitted-Cross-Domain-Policies: none •
Permissions-Policy با غیرفعال‌سازی قابلیت‌های حساس مرورگر.
Content-Security-Policy: default-src 'none'; frame-ancestors 'none'; base-uri
API. برای 'none'; form-action 'none'
Strict-Transport-Security فقط در production و زمانی که درخواست HTTPS تشخیص
داده شود.
```

این هدرها برای API مناسب هستند. اگر frontend یا HTML widget مستقل از همین backend سرو شود، باید CSP جداگانه و متناسب با نیازهای asset/script آن تعریف شود.

۱۳ امنیت دیتابیس و ها Query

کدهای بررسی‌شده عمدتاً از PDO statements prepared استفاده می‌کنند و این موضوع ریسک SQL Injection را کاهش می‌دهد. اتصال دیتابیس با utf8mb4 charset انجام می‌شود و PDO::ATTR_ERRMODE روی exception قرار دارد. خطای اتصال دیتابیس پیام عمومی برمی‌گرداند و رمز دیتابیس در خروجی چاپ نمی‌شود.

الزامات تکمیلی: production:

- کاربر دیتابیس باید حداقل دسترسی لازم را داشته باشد.
- دسترسی مستقیم اینترنت به MySQL باید بسته باشد.
- backup دیتابیس باید رمزگذاری و تست بازیابی شود.
- migration/schema باید versioned و قابل audit باشد.
- برای گزارش‌ها و جست‌وجوهای دارای sort/filter داینامیک، فقط allowlist ستون‌ها مجاز باشد.

۱۴ Model Threat

ریسک باقی‌مانده	کنترل موجود	سناریو	دسته تهدید
سرقت توکن از کلاینت در صورت XSS	JWT امضا شده، exp، token_version، iss/aud فعال بودن کاربر	جعل هویت کاربر پنل با توکن نامعتبر یا قدیمی	Spoofing
نیاز به audit endpointهای جدید	RBAC، require_site_access statements prepared	تغییر داده سایت یا گفتگوی tenant دیگر	Tampering

دسته تهدید	سناریو	کنترل موجود	ریسک باقی مانده
Repudiation	انکار عملیات مدیریتی	audit admin_audit_logs actor/IP/user-agent	پوشش همه برای همه عملیات غیرسوپردامین کامل نیست
Information Disclosure	افشای stack، SQL trace یا مسیر فایل	sanitization، production flag debug handler، error	تنظیم اشتباه APP_DEBUG
Denial of Service	spam پیام ویجت، login upload یا force brute abuse	limit، size upload limit، rate limits plan	نیاز به WAF/reverse proxy برای حملات حجیم
Elevation of Privilege	دسترسی agent به قابلیت super یا admin customer admin	require_role در endpointها	endpoint جدید بدون role check می تواند ریسک ایجاد کند

۱۵ نداشت OWASP Top ۱۰

دسته OWASP	وضعیت در پروژه	اقدام پیشنهادی
A01 Broken Access Control	RBAC و site-access وجود دارد؛ tenant فعال هم کنترل می شود.	تست خودکار endpoint برای های site/conversation.
A02 Cryptographic Failures	hash password وجود دارد؛ TLS و at-rest encryption وابسته به زیرساخت است.	اجبار HTTPS، backup encrypted، بررسی storage عمومی.
A03 Injection	PDO statements prepared رایج است.	review static برای های query داینامیک و allowlist و sort/filter.
A04 Insecure Design	validation origin در طراحی دیده شده است.	modeling threat دورهای برای AI/crawler و multi-tenant.
A05 Security Misconfiguration	headers security و separation env وجود دارد.	hardening وب سرور، APP_DEBUG=false، ET_ALLOW_EMPTY_ORIGIN=false

اقدام پیشنهادی	وضعیت در پروژه	دسته OWASP
dependency scanning در CI.	backend عمدتاً PHP بدون کتابخانه زیاد است؛ frontend/dependencies باید جدا بررسی شوند.	A06 Vulnerable Components
افزودن MFA، کوتاه‌تر کردن TTL و session/device management.	revocation token hash، login، limit rate و password policy وجود دارد.	A07 Authentication Failures
کنترل integrity و deployment artifactها.	filenames random و validation upload وجود دارد.	A08 Software/Data Integrity Failures
centralized و alerting logging، policy. retention	audit مدیریتی و logging error وجود دارد.	A09 Logging/Monitoring Failures
allowlist/denylist SSL، فعال‌سازی IP، و verification redirect. محدودیت	URL crawler خارجی fetch می‌کند و SSL verification فعلاً غیرفعال است.	A10 SSRF

۱۶ Recovery و Backup

در کد فعلی مکانیزم backup/recovery پیاده‌سازی نشده و باید به‌عنوان مسئولیت عملیاتی DevOps تعریف شود. برای این سامانه حداقل سیاست زیر لازم است:

- backup روزانه دیتابیس و نگهداری چند نسخه زمانی.
- رمزگذاری backupها و محدودیت دسترسی به آنها.
- backup از storage پیوسته‌ها و تصاویر اعلان، هماهنگ با دیتابیس.
- تست بازیابی دوره‌ای در محیط staging.
- تعریف RPO و RTO برای مشتریان SaaS.
- ثبت رخداد backup/restore در audit یا لاگ عملیاتی.

۱۷ ریسک‌ها و شکاف‌های شناخته‌شده

ریسک	شرح	اقدام لازم
SSL Crawler verification	در ai-crawler.php گزینه‌های SSL verification peer/host غیرفعال شده‌اند.	برای production فعال شود و خطاهای certificate مدیریت شوند.

ریسک	شرح	اقدام لازم
نبود OAuth	در کد فعلی login OAuth/Social پیاده سازی نشده است.	اگر نیاز محصولی وجود دارد، با provider معتبر و state/PKCE طراحی شود.
نبود MFA	login فقط رمز عبور دارد.	MFA برای admin super و admin customer اضافه شود.
توکن منفرد قابل revoke نیست	token_version همه توکن ها را باطل می کند، نه یک device خاص.	جدول session یا token blacklist اضافه شود.
Backup عملیاتی نامشخص	کد backup/recovery ندارد.	سیاست backup زیرساختی و تست restore اضافه شود.
وابستگی htaccess	محافظت upload در Apache قوی است، اما روی Nginx اعمال نمی شود.	معادل وب سرور production تعریف شود.
limit Rate دیتابیزی	در حملات بزرگ می تواند DB را درگیر کند.	limit rate در reverse proxy/WAF اضافه شود.
عدم وجود tests OpenAPI/security	قرارداد امنیتی ها endpoint تست خودکار کامل ندارد.	تست IDOR، RBAC، upload و limit rate در CI اضافه شود.

۱۸ چک لیست Production

۱. APP_ENV=production و APP_DEBUG=false تنظیم شود.
۲. JWT_SECRET تصادفی، حداقل ۳۲ کاراکتر و متفاوت از محیط های دیگر باشد.
۳. PANEL_ALLOWED_ORIGINS فقط دامنه پنل production باشد.
۴. WIDGET_ALLOW_EMPTY_ORIGIN=false و WIDGET_ALLOWED_ORIGINS فقط در موارد ضروری استفاده شود.
۵. HTTPS اجباری و HSTS فعال شود.
۶. crawler با SSL verification فعال و محدودیت SSRF اجرا شود.
۷. کاربر دیتابیس با حداقل سطح دسترسی ساخته شود.
۸. storage upload خارج از مسیر اجرای PHP یا با تنظیمات سخت گیرانه وب سرور قرار گیرد.
۹. backup دیتابیس و فایل ها رمزگذاری و restore تست شود.
۱۰. لاگ ها و audit به سامانه مانیتورینگ مرکزی متصل شوند.
۱۱. MFA برای super_admin و عملیات حساس اضافه شود.
۱۲. تست های خودکار برای tenant role، site isolation، rate access، upload limit، token-re-vocation اضافه شود.

۱۹ جمع‌بندی

امنیت فعلی پروژه برای یک MVP جدی و دمو/عرضه اولیه وضعیت قابل قبولی دارد: احراز هویت، JWT، hash رمز، ابطال نشست با `token_version`، RBAC، جداسازی CORS tenant/site، جدا برای پنل و ویجت، `upload limit`، `rate`، `headers security validation`، `audit` و مدیریتی پیاده‌سازی شده‌اند. با این حال، برای عرضه تجاری گسترده باید سخت‌سازی `production`، فعال‌سازی `verification SSL` در `crawler`، سیاست `backup/recovery`، `MFA` مانیتورینگ مرکزی و تست‌های امنیتی خودکار تکمیل شوند.